

Scansione iniziale delle vulnerabilità – Metasploitable 2

Studente: Vincenzo Lembo

Corso: Cybersecurity & Ethical Hacking

Esercitazione: W12D4 progetto finale

Argomento: Vulnerability Assessment con Nessus

Ambiente: Metasploitable 2, Kali Linux – UTM

1. Obiettivo

L'obiettivo dell'attività è eseguire una scansione di vulnerabilità sulla macchina Metasploitable 2 mediante Nessus, al fine di individuare le principali vulnerabilità presenti sul sistema.

La scansione iniziale costituisce il punto di riferimento per la successiva fase di remediation. Al termine degli interventi verrà eseguita una seconda scansione utilizzando le stesse impostazioni, così da verificare l'efficacia delle modifiche apportate.

2. Ambiente di laboratorio

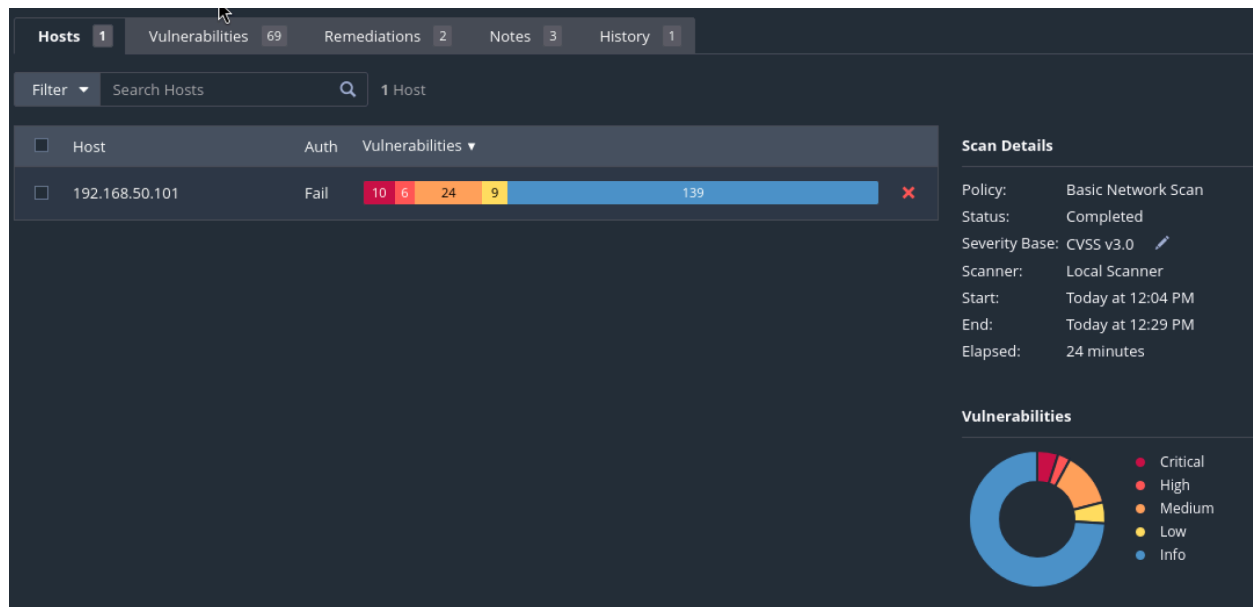
L'attività è stata svolta in un ambiente di laboratorio virtualizzato. La macchina Metasploitable 2 è stata utilizzata come sistema target vulnerabile, mentre Nessus è stato utilizzato per l'identificazione e la classificazione delle vulnerabilità.

Target Metasploitable: 192.168.50.101

3. Configurazione della scansione Nessus

È stata configurata una scansione utilizzando il template **Basic Network Scan** di Nessus, impostando come target l'indirizzo IP 192.168.50.101.

La scansione è stata eseguita mantenendo le impostazioni predefinite del template, senza utilizzare credenziali di accesso al sistema target.



4. Risultati della scansione iniziale

La scansione iniziale ha individuato vulnerabilità appartenenti a diversi livelli di severità:

Critical: 10

High: 6

Medium: 24

Low: 9

Informational: 139

La presenza di 10 rilevamenti classificati come Critical evidenzia la presenza di servizi e configurazioni fortemente vulnerabili sul sistema Metasploitable.

5. Vulnerabilità selezionate

5.1 VNC Server 'password' Password

CRITICAL VNC Server 'password' Password

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

Nessus logged in using a password of "password".

To see debug logs, please visit individual host

Port	Hosts
5900 / tcp / vnc	192.168.50.101

Plugin Details

Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015

Risk Information

Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

Default Account: true
Exploited by Nessus: true

Plugin ID: 61708

Severità: Critical

CVSS: 10.0

Porta interessata: TCP/5900

Nessus ha rilevato che il server VNC presente sul target accettava la password debole e facilmente prevedibile **password**. L'utilizzo di credenziali di questo tipo può consentire a un soggetto non autorizzato di autenticarsi al servizio VNC e ottenere accesso remoto al sistema. La remediation scelta consiste nella sostituzione della password VNC predefinita/debole con una password differente e più robusta.

5.2 Bind Shell Backdoor Detection

CRITICAL Bind Shell Backdoor Detection

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

Nessus was able to execute the command "id" using the following request :

This produced the following truncated output (limited to 10 lines) :

```
..... snip .....
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
..... snip .....
```

To see debug logs, please visit individual host

Port	Hosts
1524 / tcp / wild_shell	192.168.50.101

Plugin Details

Severity: Critical
ID: 51988
Version: 1.10
Type: remote
Family: Backdoors
Published: February 15, 2011
Modified: April 11, 2022

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Plugin ID: 51988

Severità: Critical

CVSS v3: 9.8

Porta interessata: TCP/1524

Nessus ha rilevato una Bind Shell accessibile attraverso la porta TCP 1524. Dal Plugin Output è stato possibile osservare che il servizio consentiva l'esecuzione di comandi con privilegi **root** senza un normale meccanismo di autenticazione. Questa configurazione rappresenta un rischio critico, poiché un soggetto in grado di raggiungere il servizio potrebbe ottenere accesso privilegiato al sistema. La remediation scelta consiste nella disabilitazione del servizio responsabile della Bind Shell.

6. Conclusioni

La scansione iniziale ha evidenziato numerose vulnerabilità sul sistema Metasploitable 2, tra cui 10 rilevamenti classificati come Critical.

Per la fase di remediation sono state selezionate due vulnerabilità critiche: **VNC Server 'password' Password** e **Bind Shell Backdoor Detection**. Le azioni intraprese saranno descritte separatamente nel documento Remediation. Successivamente verrà eseguita una nuova scansione Nessus per verificare l'effettiva mitigazione delle vulnerabilità selezionate.

Vincenzo Lembo